

Bonus 2: Attacco a un database MySQL

Quali sono i due indirizzi IP coinvolti in questo attacco di SQL injection in base alle informazioni visualizzate?

Gli indirizzi IP coinvolti nell'attacco di SQL injection visibili nella schermata di Wireshark sono:

- **10.0.2.4** (il client/attaccante)
- **10.0.2.15** (il server target/vittima che ospita l'applicazione vulnerabile)

Qual è la versione?

è la **5.7.12-0ubuntu1**

Cosa farebbe per l'aggressore il comando modificato di `1' OR 11 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users'`?

Il comando modificato permetterebbe all'aggressore di estrarre e visualizzare l'elenco dei nomi di tutte le colonne presenti all'interno della tabella denominata "users" del database, sfruttando i metadati di MySQL (`INFORMATION_SCHEMA.columns`).

Quale utente ha l'hash della password di `8d3533d75ae2c3966d7e0d4fcc69216b`?

1337

Qual è la password in chiaro?

charley

Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?

Poiché i siti web utilizzano comunemente database basati su SQL, il rischio principale risiede nella vulnerabilità alle **SQL injection (SQLi)**, la cui gravità effettiva dipende dalle intenzioni e dalle capacità dell'aggressore.

- **Compromissione della riservatezza:** Accesso non autorizzato a dati sensibili, informazioni personali degli utenti, dati finanziari e credenziali di accesso memorizzate nel database.
- **Bypass dell'autenticazione:** Elusione dei controlli di login per accedere al sistema fingendosi utenti privilegiati o amministratori.
- **Alterazione o distruzione dei dati:** Modifica, corruzione o cancellazione di record, tabelle o interi database, con conseguente perdita di integrità delle informazioni.

- **Esecuzione di comandi di sistema:** Nei casi più critici, se il database dispone di permessi eccessivi sul server, l'attaccante può sfruttare il motore SQL per eseguire comandi direttamente sul sistema operativo sottostante.

Naviga in internet ed esegui una ricerca per “prevenire attacchi di SQL injection”. Quali sono 2 metodi o passaggi che possono essere adottati per prevenire gli attacchi di SQL injection?

Utilizzare parametri con query/istruzioni preparate (Prepared Statements): Questa tecnica separa nettamente il codice strutturale della query SQL dai dati forniti dall'utente. In questo modo, il database interpreta l'input ricevuto rigorosamente come un semplice dato e non come un comando eseguibile, neutralizzando i tentativi di iniezione.

Filtrare e sanificare l'input dell'utente: Consiste nel convalidare, ispezionare e ripulire regolarmente tutti i dati inseriti nei moduli o negli URL (ad esempio tramite liste di autorizzazioni o whitelist e l'escaping dei caratteri speciali) per impedire che vengano interpretati in modo malevolo.